Cyber Threat Intelligence GraphRAG Assistant for Incident Response

Garyad Passmore
CS 6338 Knowledge Engineering | Dr. Erdogan Dogdu
Final capstone technical report | October 2026

Abstract

This project implements a local knowledge graph and language-model assistant for questions connecting threat groups, software, ATT&CK techniques, and mitigations. A frozen corpus contains 60 ATT&CK relationship narratives and a catalog of 50 entities. The system combines schema-constrained extraction, canonical IDs, transactional Neo4j storage, evidence-preserving graph traversal, text embeddings, and structural Node2Vec embeddings. On the 48-record extraction test split, measured exact-match precision is 0.970, recall 0.667, and F1 0.790. The report distinguishes these observations from reference-label quality and downstream answer quality. A paired 20-question experiment compares text-only retrieval, hybrid retrieval, and hybrid retrieval without Node2Vec across three seeds. Raw outputs, failures, timings, and evaluation inputs are retained so the results can be audited.

1. Problem and contribution

Incident responders often need to connect claims across separate intelligence descriptions. A report about a threat group may identify a technique while a different record describes a mitigation. A fluent answer alone is insufficient: the responder needs the directed relationship, the source record, and an explanation of what the evidence establishes. This project therefore treats traceability as a core output rather than adding source links after generation.

The contribution is an executable integration of a deliberately small, controlled CTI corpus. Its main engineering decisions are a strict evidence boundary between structured reference data and predicted assertions, stable identifiers for repeated ingestion, bounded graph retrieval, and separate text and structural vector spaces. A structural neighbor can propose evidence to inspect, but cannot itself establish a security relationship. The implementation does not infer that a mitigation guarantees prevention or that a group used every capability of associated software.

The final extends the Milestone 2 design by executing extraction, database ingestion, graph analytics, and comparative question answering. Claims in this report are limited to artifacts saved under results/. The test set is small and template-based, so these measurements characterize an in-corpus prototype rather than general incident-response effectiveness.

2. Dataset, schema, and ontology mapping

The frozen ATT&CK 19.2 subset contains 60 narrative records, 50 canonical entities, and 60 STIX-derived reference relationships. Twelve records are designated for extraction development and 48 for extraction testing. The QA file contains 20 test questions and two development questions. Source narrative text, record identifiers, reference URLs, and canonical entity metadata are distributed with the repository; no live download can silently change this experiment.

Label or record	Purpose and principal fields
Entity and subtype	Canonical ATT&CK ID, name, aliases; ThreatGroup, Software, Technique, Mitigation, Campaign
SourceDocument / Chunk	Source URL, original record ID, text, character start/end, stable chunk ID
Assertion	Subject, predicate, object, confidence, stable assertion ID
SUPPORTED_BY	Assertion-to-chunk link with verbatim evidence text
STIXRelation	Structured relationship metadata kept outside the predicted domain graph

The labeled property graph uses USES from a group to software or a technique, or from software to a technique. MITIGATED_BY points from a technique to a mitigation. ASSOCIATED_WITH connects a group to software or a campaign. Endpoint types and direction are validated before any predicate enters a Cypher statement. All values are bound as parameters. A campaign type is supported by the schema, but no campaign result is claimed for this subset.

Structured and unstructured sources

Structured ingestion reads the frozen STIX bundle and maps its external ATT&CK identifiers to catalog entities. Original STIX relation type, endpoints, modification time, and provenance are stored as STIXRelation records. RDFLib produces a Turtle representation of canonical type and label mappings. The operational graph is an LPG because traversal, property constraints, and vector indexes are direct Neo4j operations; Turtle provides an explicit semantic mapping rather than implying that OWL reasoning was executed.

The unstructured path reads narrative text and predicts relations using the language model. STIXRelation metadata is excluded from retrieval and the GDS projection. This separation is essential: loading known reference relations as if they were extracted assertions would inflate both extraction and QA performance. Structured metadata may identify entities, while only accepted text-supported assertions supply the evaluated domain edges.

Each narrative includes a Record context header naming its designated endpoint pair. This is a catalog-assisted relation-classification setting, not unrestricted entity discovery. Reference labels are derived from STIX and remain silver labels until independently reviewed. In particular, gold-038 labels a Lazarus/MagicRAT relationship as USES although its narrative uses weaker association wording. The original label is preserved and the discrepancy is reported rather than silently corrected after observing predictions.

3. Extraction and named entity disambiguation

Documents are split into 1,800-character chunks with 200-character overlap. Every chunk retains document ID, source URL, and exact character offsets. The frozen subset currently produces one chunk per narrative. Entity IDs come from the catalog; gold relationships and reference answers never enter the extraction request. The prompt restricts relations to the designated endpoint pair, forbids speculation and negation, and asks for a verbatim evidence substring.

Control	Executed configuration
Extractor	llama3.1:8b through the local Ollama API
Sampling	Temperature 0; seed 42; context 8,192; output ceiling 2,500 tokens
Output contract	Pydantic entities/relations JSON schema; extra fields forbidden
Repair ceiling	Three total attempts, including initial request; shared network/JSON attempt budget
Acceptance	Confidence >=0.85 accepted; 0.60 to <0.85 review; <0.60 rejected
Evidence validation	Known canonical IDs; valid endpoint types; directed predicate; exact substring

A valid JSON object can still be semantically invalid. The parser rejects duplicate entities, unknown or mistyped IDs, dangling relation endpoints, illegal predicate directions, and evidence that is not literally present in the input. It does not claim to prove entailment: an exact quote may still support a weaker statement than the predicted predicate. Model confidence is a self-reported estimate, not a calibrated probability.

Resolution and collisions

Canonicalization prioritizes ID, exact name, and normalized alias matches. Fuzzy similarity of at least 0.92 proposes human review only when the best candidate is separated from the next by at least 0.08. A shared alias is not automatically merged. The final resolver can select one colliding candidate when an explicit canonical ID in the query provides unique context; otherwise it preserves the review state. The tests exercise both unresolved collisions and resolution by explicit context.

For extraction, schema validation checks the model-selected ID and name against the catalog. For online QA, query mentions are resolved against the persisted canonical catalog before bounded graph traversal. These are constrained NED operations within a known vocabulary. They do not establish general performance on unseen organization names, newly discovered malware, or ambiguous cross-report mentions.

All 60 final extraction records are retained with raw outputs, elapsed time, validation errors, and attempt histories. 17 records exhausted the attempt budget and were quarantined. A preliminary instrumentation pilot is retained separately and excluded from the final score. The final run used the same frozen extraction prompt and thresholds; no test-specific prompt adjustment or manual insertion of missing relations is used.

An evidence-preserving failure is preferable to manufacturing an edge. Quarantined, review, and rejected relations are excluded from accepted predictions. Their missing relationships therefore remain false negatives when scoring against the test reference, and can also cause missing links or abstentions downstream.

4. Transactional ingestion and provenance

Ingestion revalidates each raw extraction before writing. A transaction creates or merges the source document and chunk, merges canonical entities, and writes accepted assertions with their supporting chunk relationships. SHA-256 assertion IDs are derived from document ID, subject, predicate, and object. Chunk IDs combine the source record ID and character offset. Uniqueness constraints ensure that repeated execution does not multiply these records.

Observed database check	Saved result
After first ingestion	{'nodes': 273, 'assertions': 43, 'chunks': 60}
After repeated ingestion	{'nodes': 273, 'assertions': 43, 'chunks': 60}
Idempotency verified	True
Rollback verified	True
Database version	[{'name': 'Neo4j Kernel', 'versions': ['5.26.4']}]

The rollback check deliberately creates a probe node within a transaction and raises an exception before commit. A subsequent query confirms that the probe does not exist. The repeat-ingestion check compares node, assertion, and chunk counts before and after a second pass. These are live integration observations, not mocked unit-test outcomes. The server enforces a five-second default transaction timeout; the client also bounds connection time and managed retry time.

Evidence attached to the relationship

Each accepted domain relationship carries document ID, confidence, assertion ID, and a derived=false marker. The Assertion record connects its subject and object and has a SUPPORTED_BY edge containing the original evidence substring. The source document links to the chunk and URL. This gives the answer engine a route from a directed graph claim back to the exact text used during extraction. It also keeps multiple source documents distinct even when they assert the same tuple.

Inverse reasoning is implemented as bounded traversal that can follow a persisted edge in either direction. The returned fact always retains its original subject, predicate, and object. Thus a reverse lookup corresponding to USED_BY does not create a new independent observation. The generation prompt distinguishes derived multi-hop paths from direct reports. Traversal does not assert transitive USES relationships or create unsupported threat attribution.

Runtime isolation and reproducibility

Execution uses a dedicated local Neo4j Community instance with GDS and APOC available. Existing user databases are not edited. Credentials remain in local environment configuration and are excluded from the submission. The reproducibility manifest records model digests, Python and package versions, and dataset/prompt hashes. Database counts and index states are saved in ingestion.json. Structured ingestion counts and the RDF mapping are stored separately for inspection.

The prototype assumes the frozen corpus and a dedicated single-user database. It does not implement production authorization, scheduled refresh, multi-tenant isolation, or a deletion/version-migration workflow. A later corpus revision should create a new experiment directory and database rather than mixing old predictions with changed source records.

5. Graph data science and structural embeddings

The analytics projection contains Entity nodes and only accepted USES, MITIGATED_BY, and ASSOCIATED_WITH relationships. Its edges are unweighted and projected as undirected for structural embedding. It excludes document, chunk, provenance, and STIXRelation records. This makes the structural task about entity neighborhoods while preserving provenance separately in the database.

Metric or algorithm	Measured result / configuration
Projected entities	50
Projected relationships (undirected representation)	86
Weakly connected components	11
PageRank	Damping 0.85, 20 maximum iterations; scores in analytics_42.json
Node2Vec write result	{'nodePropertiesWritten': 50, 'computeMillis': 1147}
GDS version	2.13.3

Top PageRank entity	Score
G0007	6.8351
G0046	2.1283
T1005	1.9425
M1017	1.6445
G0032	1.6219

PageRank supplies the final-rubric graph analytics execution. Here it characterizes centrality within the selected undirected entity graph; it is not a threat-severity score or evidence that a technique is prevalent in the wild. WCC provides a second diagnostic of disconnected components. Sampling only four threat groups and selected techniques strongly shapes both measurements.

Node2Vec fit and candidate lookup

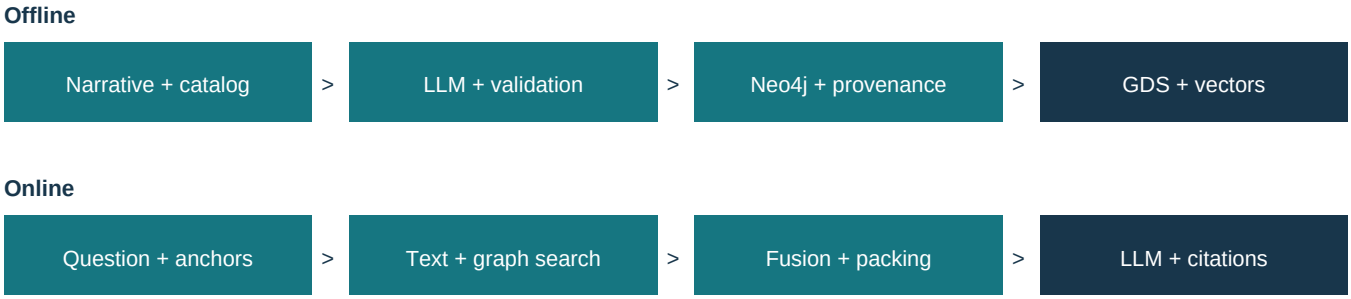
GDS Node2Vec fits 128-dimensional embeddings with walk length 30, 80 walks per node, returnFactor 1.0, inOutFactor 0.5, window size 5, negative sampling rate 5, and 20 iterations. Concurrency is one, and the experiment repeats with seeds 42, 43, and 44. Vector dimensions are checked after each write and the actual vectors are exported. Seed changes are treated as experimental variation; exact bitwise reproducibility is not assumed across runtime or algorithm implementations. The executed configuration is retained with every analytics artifact.

Text chunks occupy a separate 768-dimensional nomic-embed-text:v1.5 space. Text lookup embeds the query with the search_query prefix and narrative chunks with search_document. No cosine comparison mixes the text and graph spaces. For hybrid retrieval, structural neighbors of resolved anchors propose additional graph candidates; facts still require a persisted accepted relationship and its supporting chunk. Removing this proposal step defines the hybrid-without-Node2Vec ablation.

The graph is small enough that structural neighbors may be redundant or may introduce unrelated paths. Therefore a fitted embedding is evidence of execution, not evidence of retrieval benefit. The paired QA results determine whether this step helps this benchmark, and the report does not assume the full hybrid configuration must win.

6. LLM integration and GraphRAG execution

POST /query now constructs a live QA engine by default. It accepts text_only, hybrid, or hybrid_without_node2vec and validates chunk and hop limits through the request schema. The engine resolves query anchors from persisted entity metadata, embeds the question, retrieves candidate text chunks, and optionally traverses one or two graph hops. The maximum hop count is selected from a validated integer bound; arbitrary generated Cypher is never executed.



Text search proposes 20 chunks using the 768-D query vector. Full hybrid adds five structural neighbors per anchor; the ablation omits that proposal. Reciprocal rank fusion uses k=60 and selects five chunks by default. The generator receives the question, packed text, directed facts, and source labels; the response includes citations, subgraph context, and elapsed time.

Text-only generation receives the retrieved narrative chunks without graph facts. Both hybrid conditions fuse text and graph-supported chunk rankings. The implementation orders graph facts connected to explicit anchors before facts proposed only by structural neighbors. All three conditions use the same model, answer instructions, default context count, and source corpus. This controls major generation differences while allowing retrieval to vary.

Context and citation boundary

The evidence pack uses a conservative 6,000-byte JSON ceiling. For the byte-level model tokenizer this is at most 6,000 byte pieces, while usually being substantially fewer tokens. The cap intentionally leaves room inside the 8,192-token context for instructions, the question, schema, and output. Facts whose supporting chunks are excluded from the pack are also removed. Actual packed context is saved per answer, so the evaluation uses what the model saw rather than an earlier candidate list.

The generator is llama3.1:8b at temperature zero with a seed matched to the run and a 700-token output limit. It returns structured JSON containing answer, answered/insufficient_evidence status, and cited labels. Short labels such as C1 map back to immutable full chunk IDs in the response. This mapping replaced brittle long-ID copying during an excluded wiring pilot; the final prompt is frozen across conditions. The engine rejects truncated output, unknown labels, and answered responses with no citations. Citation records return document ID, URL, and text. Structural citation validity does not prove sentence-level entailment.

Dependency or output-validation failure returns HTTP 502 instead of a fabricated answer. The previous unwired checkpoint 503 path is removed. Health checks examine database population and model availability, while the integration evidence records an actual successful request separately. The API is sufficient for the final demonstration; a separate graphical frontend is outside the required scope.

The prompt tells the model to treat evidence as data, stay within supplied sources, qualify derived paths, and abstain when a required link is missing. These are model instructions rather than formal guarantees of factual correctness. A deployment intended for operational CTI would additionally need explicit claim-level support checks, adversarial evidence tests, and a reviewed negative-question set.

7. Comparative benchmark and observed results

The benchmark runs the same 20 test questions under three retrieval modes and seeds 42, 43, and 44, producing 180 planned observations. Each seed is paired across the modes. Node2Vec is refitted before the corresponding seed run. The 12/48 extraction split is retained; QA references are read only by the benchmark harness after generation and never supplied to the engine. Dataset, prompts, and thresholds remain frozen during the final experiment.

Mode	Runs / errors	Evidence recall	Abstention	p95 total (s)
Text only	60 / 0	0.675	0.000	1.07
Hybrid, no N2V	60 / 0	0.625	0.050	1.14
Hybrid	60 / 0	0.600	0.050	1.04

Full hybrid evidence recall is 0.600, compared with 0.675 for text-only retrieval: a difference of -7.5 percentage points. Thus the structural proposal and fusion configuration does not establish a retrieval improvement on this benchmark. This negative finding is retained rather than selecting a favorable seed or replacing missing extracted edges with STIX reference relationships.

Evidence recall is the fraction of each question's reference supporting documents present in the actual packed contexts. The metric measures evidence availability rather than answer correctness. Path-ID coverage checks whether all reference path IDs appear in the answer; it is a lexical diagnostic, not factual accuracy. Citation-ID validity checks context membership. It is enforced by the response gate, making 100% validity among completed responses a structural property rather than an independent quality result. It does not measure entailment or correct source selection.

Latency and unsuccessful cases

Retrieval latency includes query embedding, database access, ranking, and evidence packing. Total latency additionally includes generation and output validation. Values are elapsed wall-clock measurements on this machine. The first request can include model loading, and no dedicated warm-up is removed from the saved runs. Accordingly these are observed mixed-start timings, not a controlled proof of the original warm-model p95 targets of one second for retrieval and 30 seconds for total answering.

Failed generation, dependency failures, and invalid citation output remain explicit error rows with elapsed time. Summary quality metrics use completed rows and report errors beside their denominators; they do not quietly turn failures into valid abstentions. Per-seed values are provided in benchmark_summary.csv. The pooled table is descriptive because the same questions recur across seeds; 180 observations are not 180 independent questions.

Extraction results

Split	TP	FP	FN	Precision	Recall	F1
Development	10	0	2	1.000	0.833	0.909
Test	32	1	16	0.970	0.667	0.790

Exact-match scoring keys each prediction by document, subject, directed predicate, and object. Accepted predictions in a scored record with incorrect endpoints count as false positives; omissions count as false negatives. Duplicate tuples do not multiply true positives. The score is conditional on the provided entity catalog and designated endpoint header. Per-predicate results and quarantined extraction counts are preserved in extraction_metrics.json.

8. Evaluation quality, examples, and related work

Local evaluation and RAGAS

Mode	Faithfulness	Relevancy	Context recall	Factual F1
Text only	0.346 (20)	0.803 (20)	0.450 (20)	0.246 (20)
Hybrid, no N2V	0.539 (20)	0.767 (20)	0.483 (20)	0.413 (20)
Hybrid	0.539 (20)	0.802 (20)	0.483 (20)	0.383 (20)

Cells report the mean score with the number of finite rows in parentheses.

In this judge audit, factual F1 is +13.6 percentage points higher for full hybrid and +16.7 points higher without Node2Vec than for text-only answers. Graph context therefore improves this automated answer-quality measure despite lower evidence recall. The ablation performs best; Node2Vec supplies no measured advantage here. This is a local-judge result on 20 paired questions, not independently established human factual accuracy.

The local RAGAS artifact contains 60 evaluated rows from the seed-42 cohort: all 20 questions under all three modes. This bounded judge audit complements deterministic metrics for all 180 attempts. Metrics use RAGAS 0.2.15 and qwen2.5:14b at temperature zero. Response relevancy uses strictness=1. The judge context is 8,192 tokens and output is capped at 2,048 tokens. Failures or non-finite scores remain missing rather than becoming zero. Row IDs, modes, seeds, and finite-score denominators are saved in ragas.csv.

Automated judges are a second model measurement, not independent human ground truth. Their score can depend on prompt formatting, long source identifiers, and the judge's interpretation of qualified paths. Human factuality, completeness, and coherence use a 1-5 rubric. A blank worksheet is supplied for the student or reviewer; no human ratings are invented or substituted with model scores.

Saved example: qa-01 / seed 42

Question: In this frozen subset, which mitigation is linked to Security Account Manager (T1003.002) as reported for APT29, and what is the two-edge evidence path?

Observed answer: The mitigation linked to Security Account Manager (T1003.002) as reported for APT29 is 'reg save' command to save registry hives. The two-edge evidence path is: APT29 (G0016) -> Security Account Manager (T1003.002) -> 'reg save' command to save registry hives.

The complete answer, original chunk IDs, source URLs, graph facts, and model output are preserved in the benchmark JSON.

Observed failure: this answer identifies the reg save command as a mitigation. The reference path ends in User Training (M1017). A valid citation to a credential-dumping narrative does not support the claimed mitigation, and all retrieval modes can fail this way when the required mitigation evidence is absent from the packed context.

Related work and comparison boundary

AttacKG builds technique knowledge graphs from CTI reports [1]. CTINexus combines LLM extraction, entity alignment, and relation prediction [2]. Their corpora and relation inventories differ from this endpoint-conditioned task, so published F1 values are not direct baselines. CTIBench addresses multiple CTI tasks [3]; external CTI-ATE evaluation remains future work.

Node2Vec supplies random-walk structural representations [4]; RAGAS supplies automated RAG evaluation [5]. This experiment compares retrieval conditions within one frozen corpus. It does not introduce a new embedding method or an independent CTI benchmark.

9. Limitations, reproducibility, and conclusion

The strongest limitation is evaluation independence. The corpus is tiny; questions follow a limited set of templates; development and test questions can share entities and source narratives. The extraction reference is STIX-derived and has not received independent annotation adjudication. The Record context header supplies endpoint identity, so extraction scores cannot be generalized to unconstrained long-form CTI reports. The gold-038 discrepancy remains visible in the error analysis.

The current QA set primarily asks answerable positive questions. An observed abstention rate therefore describes missing evidence and model behavior, not reliable detection of unanswerable questions. Citation membership cannot certify factual grounding. Node2Vec can add neighbors without improving evidence recall, and PageRank centrality in this subset should not guide operational prioritization. Model outputs can still overstate associations; the saved text and graph traces make those cases reviewable.

Reproduction requires Python 3.11+, a dedicated Neo4j 5.26 database with a compatible GDS plugin, and local Ollama models llama3.1:8b, nomic-embed-text:v1.5, and qwen2.5:14b for the judge. The README provides ordered setup, extraction, loading, analytics, benchmark, and evaluation commands. Results use resumable files; a new scientific run must use a clean results directory or archive the old artifacts first. Secrets and downloaded model weights are not committed.

The completed implementation demonstrates the four required pillars: structured and unstructured ingestion, graph analytics, schema-constrained LLM extraction with canonical identity resolution, and multi-hop GraphRAG with traceable evidence. The report intentionally separates execution success from evidence of quality. The most useful next steps are independent label review, more varied questions and negative controls, held-out source reports, and claim-level citation assessment before expanding the application.

References

[1] Z. Li et al., "AttacKG: Constructing Technique Knowledge Graph from Cyber Threat Intelligence Reports," 2022. https://arxiv.org/abs/2111.07093

[2] Y. Cheng et al., "CTINexus: Automatic Cyber Threat Intelligence Knowledge Graph Construction Using Large Language Models," IEEE EuroS&P, 2025. https://ctinexus.github.io/

[3] M. T. Alam et al., "CTIBench: A Benchmark for Evaluating LLMs in Cyber Threat Intelligence," 2024. https://arxiv.org/abs/2406.07599

[4] A. Grover and J. Leskovec, "node2vec: Scalable Feature Learning for Networks," 2016. https://arxiv.org/abs/1607.00653

[5] S. Es et al., "Ragas: Automated Evaluation of Retrieval Augmented Generation," 2023. https://arxiv.org/abs/2309.15217

[6] MITRE, ATT&CK STIX data, frozen version 19.2. https://github.com/mitre-attack/attack-stix-data

[7] Neo4j, Graph Data Science: Node2Vec documentation. https://neo4j.com/docs/graph-data-science/current/machine-learning/node-embeddings/node2vec/